

Security+ 4.1 · Hardening Targets

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.1** —
Hardening Targets (10:11) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Hardening targets span wireless (WPA2/3-Enterprise), mobile (MDM, anti-jailbreak), servers (close ports, remove unnecessary services), workstations, IoT (segment!), ICS/OT (air gap/DMZ), and cloud (IAM + security groups).

High-Yield Core Concepts Tested on Exam

- IoT (cameras, sensors): the MOST overlooked attack surface — segment it
- ICS/OT (factory floor): air gap or industrial DMZ
- Servers: close unused ports and remove unnecessary services
- Cloud: enforce IAM policies and security groups
- Mobile: MDM and anti-jailbreak/anti-root controls

Exam Tips & Classic Scenarios

- 'segmenting IoT devices' = security control for IoT
- 'air gap' or 'industrial DMZ' = ICS/OT hardening
- 'close ports, remove services' = server hardening

Typical Exam Scenario: 'Company IP cameras are on the same VLAN as workstations' = risky — segment IoT.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.1 — Hardening Targets)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An isolated subnet that exposes public servers (web/email) while protecting the internal network is a:

- A)** Voice VLAN
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Physically isolate a critical system from the network (with no connection at all):

- A) Air gap**
- B) VLAN**
- C) VPN**
- D) NAT**

3. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'IoT (camera, sensor): the MOST forgotten surface — segment'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: IoT (camera, sensor): the MOST forgotten surface — segment...**
- D) Allow shared access among administrators with generic credentials**

4. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.1) exam, an analyst evaluates the following technical requirement: 'ICS/OT (factory): air gap or industrial DMZ'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: ICS/OT (factory): air gap or industrial DMZ...**
- D) Allow shared access among administrators using generic credentials**

5. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'segmenting IoT devices' = security control for IoT. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: 'segmenting IoT devices' = security control for IoT...**

6. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'company IP cameras are on the same VLAN as workstations' = risky — segment IoT.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'company IP cameras are on the same VLAN as workstations' = risky — segment IoT...

7. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'IoT (camera, sensor): the MOST forgotten surface — segment'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: IoT (camera, sensor): the MOST forgotten surface — segment...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'ICS/OT (factory): air gap or industrial DMZ.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: ICS/OT (factory): air gap or industrial DMZ...

9. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'segmenting IoT devices'=security control for IoT'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'segmenting IoT devices'=security control for IoT...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Hardening Targets): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'company IP cameras are on the same VLAN as workstations'=risky — segment IoT. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'company IP cameras are on the same VLAN as workstations'=risky — segment IoT...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — DMZ (screened subnet).

✓ **Why it's correct:** The correct answer is 'DMZ (screened subnet)'. A DMZ (Demilitarized Zone), also called a screened subnet, is an isolated network segment that sits between the trusted internal network and the untrusted external network (such as the Internet). It hosts public-facing servers, such as web, email, DNS, and FTP, which need to be accessible externally. The goal is that if one of these servers is compromised, the attacker does not have direct access to the internal network, because firewalls control traffic between the DMZ and the internal network. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.2), describes the DMZ as a security zone for exposing public services in a controlled manner. The question describes exactly this function: an isolated subnet that exposes public servers while protecting the internal network.

✗ **Why the others are wrong:**

- *Voice VLAN:* A voice VLAN is a virtual local area network dedicated to VoIP (Voice over IP) traffic, separating it from data to ensure quality of service (QoS) and security. It is not designed to expose public servers to the Internet; on the contrary, it isolates voice traffic. It does not provide the isolation between internal and external networks that a DMZ provides. Therefore, it does not meet the requirement of protecting the internal network while exposing public services.
- *VPN:* A VPN (Virtual Private Network) is a technology that creates an encrypted tunnel to transmit data securely over untrusted networks, enabling remote access or branch interconnection. Although it improves communication security, it is not an isolated subnet for hosting public servers. A VPN can be used to access the DMZ, but it does not replace the DMZ. The question asks for a network zone that exposes public servers, which is not the primary function of a VPN.
- *Intranet:* An intranet is a private internal network that uses Internet technologies (such as HTTP, FTP) to share information within an organization. It is accessible only to authorized users and is not exposed to the external public. Therefore, it is not used to host public servers that need to be accessed from the Internet. The intranet is the opposite of a DMZ in this respect: it is internal and restricted, not a controlled exposure zone.

2) A — Air gap.

✓ **Why it is correct:** Air gap (or physical isolation) is the practice of physically separating a critical system from any network, including the Internet, LAN, and WAN, so that there is no physical or logical connection. This prevents remote attacks and data exfiltration over the network. It is used in high-security environments such as industrial control systems (ICS/SCADA), military networks, and voting systems. According to SY0-701 objective 3.3 (security architecture) and 4.1 (security controls), air gap is the strongest isolation measure. The question describes exactly isolating a critical system from the network with no connection, which is the definition of air gap.

✗ **Why the others are wrong:**

- *VLAN:* VLAN (Virtual Local Area Network) is a logical segmentation of a physical network, created on switches, that allows separating broadcast domains and applying security policies. Although it improves logical isolation, it is not physical isolation; devices in different VLANs still share the same physical infrastructure and can be interconnected by routing or misconfiguration. The question requires PHYSICAL isolation with no connection, which VLAN does not provide, as it maintains underlying logical and physical connectivity.
- *VPN:* VPN (Virtual Private Network) is an encrypted tunnel that allows secure communication over untrusted networks, such as the Internet. It provides confidentiality and integrity, but does not physically isolate the system; on the contrary, it connects the system to a remote network securely. The question asks for physical isolation with no connection, which is incompatible with VPN, which

presupposes network connectivity.

- **NAT:** NAT (Network Address Translation) is a technique that translates private IP addresses to public ones (and vice versa), allowing multiple devices to share a single public IP address. It hides the internal topology but does not physically isolate; the system remains connected to the network. The question requires physical isolation with no connection, which NAT does not offer, as it is a routing mechanism that maintains connectivity.

3) C — Implement the corresponding solution: IoT (camera, sensor): the MOST forgotten surface — segment....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): IoT (camera, sensor): the MOST forgotten surface — segment.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

4) C — Implement the corresponding solution: ICS/OT (factory): air gap or industrial DMZ....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): ICS/OT (factory): air gap or industrial DMZ. An air gap physically isolates OT networks from IT/business networks, while an industrial DMZ provides a segmented buffer zone for controlled data exchange, both preventing lateral movement from compromised IT systems into critical industrial control systems.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'segmenting IoT devices' = security control for IoT....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): 'segmenting IoT devices' = security control for IoT. Network segmentation isolates IoT devices from critical systems, limiting the attack surface and preventing lateral movement in case of compromise. This is a key hardening technique for IoT.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: 'company IP cameras are on the same VLAN as workstations' = risky — segment IoT....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): 'company IP cameras are on the same VLAN as workstations' = risky — segment IoT. This correctly identifies the risk of having IoT devices like IP cameras on the same network segment as workstations, as compromised IoT devices can be used to pivot and attack other systems. Segmentation isolates IoT traffic to limit lateral movement.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: IoT (camera, sensor): the MOST forgotten surface — segment....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): IoT (camera, sensor): the MOST forgotten surface — segment. IoT devices are often overlooked in security hardening, making them a prime target. Network segmentation isolates IoT devices from critical systems, limiting lateral movement and reducing the attack surface.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: ICS/OT (factory): air gap or industrial DMZ....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): ICS/OT (factory): air gap or industrial DMZ. Industrial control systems require strict isolation from corporate networks, either through physical air gaps or demilitarized zones to prevent lateral movement.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'segmenting IoT devices'=security control for IoT....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Hardening Targets): 'segmenting IoT devices'=security control for IoT.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'company IP cameras are on the same VLAN as workstations'=risky — segment IoT....

✓ **Why it's correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 4.1 (Hardening Targets): 'company IP cameras are on the same VLAN as workstations'=risky — segment IoT.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

